



Weekly Cyber Threat Intelligence Report

Reporting window: 28 September - 5 October 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add



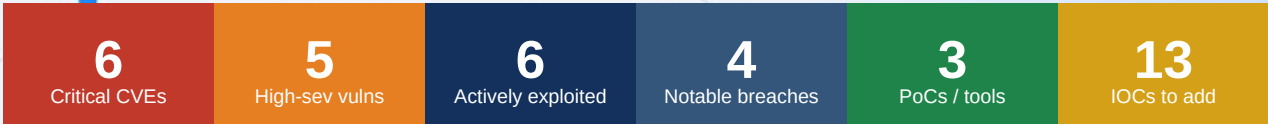
Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary



This week's report covers **28 September - 5 October 2026**. Dominant themes: **exploited edge and collaboration platforms** (Citrix NetScaler dual zero-days, FortiMail, SharePoint, Kiteworks), **autonomous AI agents** acting as intruders (DIVD, government SQLi) and as lures (malicious custom GPTs), and **trusted-infrastructure abuse** by malware (Tailscale, AMD drivers, fake Zoom). A 3-million-person Pentagon DMDC breach and the DTU IAM breach headline the incidents. No Australia-specific items were identified; APAC is represented by China-based Warlock.

KEY CALLOUTS - SECTOR IMPACT

Who is affected this week

GOVERNMENT	8 items
Sustained pressure on public bodies: DMDC (3M people), AI agents probing US and Canadian sites, exploited NetScaler/SharePoint and Star Blizzard phishing.	
CRIT	CVE-2026-65660 - Microsoft SharePoint Server code injection, exploited and in KEV
CRIT	CVE-2026-88771 / 88772 - Citrix NetScaler ADC/Gateway dual unauthenticated RCE zero-days
HIGH	Apple CoreGraphics zero-day exploited in targeted attacks (iOS/iPadOS 26.7.1, macOS 26.7.1 / 15.8.1)
HIGH	Kiteworks: Advanced Forms flaw behind precautionary shutdown patched (CVE-2026-102109)
HIGH	Pentagon DMDC breach exposes about 3 million people after a roughly 10-month intrusion
HIGH	Star Blizzard (Russia) refines phishing with new RedFlick delivery technique
HIGH	Warlock (China-based) widens SharePoint exploitation against critical infrastructure
MEDI	Autonomous AI agents launch SQL injection against US and Canadian government sites
FINANCIAL	2 items
HIGH	Kiteworks: Advanced Forms flaw behind precautionary shutdown patched (CVE-2026-102109)
MEDI	Microsoft's official X account hijacked to pump a fake Clippy crypto token
ENERGY / UTILITIES	1 item
Warlock's SharePoint campaign reaches water and telecom operators.	
HIGH	Warlock (China-based) widens SharePoint exploitation against critical infrastructure
TELECOM	1 item
HIGH	Warlock (China-based) widens SharePoint exploitation against critical infrastructure
DEFENSE / AEROSPACE	1 item
HIGH	Pentagon DMDC breach exposes about 3 million people after a roughly 10-month intrusion
EDUCATION	2 items
DTU's IAM compromise and Frontline Education's third-party leak show education systems holding large identity stores.	
HIGH	DTU (Technical University of Denmark) IAM breach - up to 200,000 users
MEDI	Frontline Education breach exposes school district employee SSNs via third-party software flaw

TECHNOLOGY / SaaS / DEV

8 items

Developer and platform risk: Roller and GitLab AI Gateway RCE, PhantomSub and Kothamine on npm, and DIVD hit via Zammad.

- CRIT CVE-2026-82384 - Apache Roller <= 6.1.5 unauthenticated XML-RPC deserialization RCE (CVSS 9.8)
- CRIT CVE-2026-90970 - GitLab AI Gateway (Duo Agent Platform) sandbox escape to RCE (CVSS 9.9)
- HIGH Autonomous AI agent breaches DIVD via Zammad zero-days
- MEDI Microsoft's official X account hijacked to pump a fake Clippy crypto token
- MEDI PhantomSub: 101 malicious npm packages silently add developers' WhatsApp accounts to attacker groups
- HIGH Cloudflare Containers cross-tenant exposure of residual disk data (patched)
- HIGH Kothamine RAT ships via npm and hides C2 inside Tailscale's tailcat
- HIGH Public exploit repo for Apache Roller CVE-2026-82384 (ysoserial chain and bulk scanner)

CROSS-SECTOR / ENTERPRISE IT

12 items

Edge appliances, Apple, OpenSSL, Spectre BTR and ClickFix lures affect any organisation regardless of sector.

- CRIT CVE-2026-104286 - Fortinet FortiMail path traversal exploited as zero-day (CVSS 9.8)
- CRIT CVE-2026-65660 - Microsoft SharePoint Server code injection, exploited and in KEV
- CRIT CVE-2026-88771 / 88772 - Citrix NetScaler ADC/Gateway dual unauthenticated RCE zero-days
- HIGH Apple CoreGraphics zero-day exploited in targeted attacks (iOS/iPadOS 26.7.1, macOS 26.7.1 / 15.8.1)
- HIGH CloudSyncD: macOS backdoor delivered through a fake Zoom installer
- HIGH Malicious custom ChatGPTs push ClickFix pages that install a RAT
- HIGH OpenSSL and wolfSSL each patch roughly a dozen vulnerabilities, including high severity
- HIGH Spectre v2 'Branch Target Reuse' (BTR) leaks Linux root password hash on Intel, AMD and Arm

+ 4 more in the sections below

AUSTRALIA - SPECIFIC

Local orgs & data

No Australia-specific items identified this reporting window.

APAC - SPECIFIC

Regional incidents & actors

Warlock (China-based) widens SharePoint exploitation against critical infrastructure

HIGH **VERIFIED** **APT** **China** **SharePoint**
SecurityWeek and The Record report the China-based Warlock collective, active against SharePoint since mid-2025, is expanding attacks on critical-infrastructure operators including water and telecom, with ransomware used in Portuguese- and Spanish-speaking countries. Year-old SharePoint flaws are still the entry point, and the newly exploited CVE-2026-65660 adds to the on-prem SharePoint exposure covered below.

PoC: Active exploitation in the wild

Refs: securityweek.com · therecord.media · securityonline.info

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

CVE-2026-104286 - Fortinet FortiMail path traversal exploited as zero-day (CVSS 9.8)

CRITICAL

VERIFIED

KEV

Exploited

Fortinet

Unauthenticated attackers can write arbitrary files to FortiMail and reach code execution. Fortinet warned of exploitation as a zero-day on 1 Oct and the flaw is in CISA KEV. Apply the fixed release immediately and review FortiMail for unexpected files and web shells.

PoC: Active exploitation in the wild

Refs: bleepingcomputer.com · thehackernews.com · securityweek.com

CVE-2026-65660 - Microsoft SharePoint Server code injection, exploited and in KEV

CRITICAL

VERIFIED

KEV

Exploited

SharePoint

Code injection (CWE-94) in SharePoint Server 2016/2019/Subscription Edition, dangerous when chained for pre-auth RCE on servers permitting anonymous access. Now confirmed exploited with a CISA deadline of 28 Sep. SharePoint 2016 and 2019 reached end of life on 15 Jul 2026, so those builds have no patch path - migrate. Enable AMSI, require MFA for admins and hunt for web shells.

PoC: Active exploitation in the wild

Refs: cyber.gc.ca · securityweek.com · esecurityplanet.com

CVE-2026-82384 - Apache Roller <= 6.1.5 unauthenticated XML-RPC deserialization RCE (CVSS 9.8)

CRITICAL

VERIFIED

CVE

PoC

Java

Pre-auth Java deserialization in Roller's XML-RPC endpoint yields full RCE with no interaction. Apache's dev list and OSV/VulDB now carry the advisory (primary-source gap from the earlier sweep is closed) and a working exploit repo is public, so mass scanning is likely. Upgrade past 6.1.5 or disable XML-RPC, and check exposed instances for web shells.

PoC: Public - PoC and ysoserial exploit with bulk scanner - github.com/murrez

Refs: mail-archive.com · osv.dev · vuldb.com

CVE-2026-88771 / 88772 - Citrix NetScaler ADC/Gateway dual unauthenticated RCE zero-days

CRITICAL

VERIFIED

KEV

Exploited

Edge

Citrix confirmed two actively exploited pre-auth RCE flaws after admins began pulling appliances offline; one affects NetScaler in its default configuration. Exploitation is confirmed across multiple customer environments worldwide and has since been used to drop web shells, tunnels and root access (BleepingComputer, 29 Sep). CISA set a federal patch deadline of 30 Sep. Patch to the fixed builds, isolate unpatched appliances and hunt for web shells and unexpected admin sessions.

PoC: Active exploitation in the wild (web shells, tunnels, root); no public PoC link

Refs: bleepingcomputer.com · thehackernews.com · cyber.gc.ca

CVE-2026-90970 - GitLab AI Gateway (Duo Agent Platform) sandbox escape to RCE (CVSS 9.9)

CRITICAL

VERIFIED

CVE

AI

GitLab

A low-privilege user with Duo Agent Platform access can escape the prompt-template sandbox via a crafted flow configuration and run arbitrary commands on self-hosted AI Gateway. Fixed in 19.2.4, 19.3.2 and 19.4.1; GitLab.com and Dedicated were already protected. No exploitation reported as of 2 Oct. Upgrade and review who holds Duo Agent Platform access.

Refs: bleepingcomputer.com · forkast.news · sqmagazine.co.uk

Apple CoreGraphics zero-day exploited in targeted attacks (iOS/iPadOS 26.7.1, macOS 26.7.1 / 15.8.1)

HIGH

VERIFIED

Apple

Zero-day

Mobile

Apple patched a CoreGraphics memory-corruption flaw used in what it called an extremely sophisticated attack; reporting credits Meta with the find. Update iPhones, iPads and Macs now and enable Lockdown Mode for at-risk users. Separately, a fake iPhone Duo preorder page serves the DarkSword exploit kit to vulnerable iPhones.

PoC: Active exploitation in the wild (targeted); no public PoC

Refs: theregister.com · securityweek.com · bitdefender.com

Fortra BoKS critical flaws - authentication bypass, command execution, memory corruption

CRITICAL

UNVERIFIED

Fortra

PAM

Fortra patched critical vulnerabilities in BoKS privileged-access software, including an Active Directory authentication bypass, shell command execution and memory corruption. CVE IDs vary by listing (for example CVE-2026-79896 out-of-bounds read, CVSS 7.5) and should be confirmed against the Fortra advisory. Patch servers and agents and restrict network exposure of BoKS admin services.

Refs: securityweek.com · cloudlinktech.com

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

Kiteworks: Advanced Forms flaw behind precautionary shutdown patched (CVE-2026-102109)

HIGH

VERIFIED

MFT

Kiteworks

SQLi

After asking customers to shut down servers on federal threat intelligence on 25 Sep, Kiteworks disclosed the cause as a vulnerability in Advanced Forms (VulDB lists CVE-2026-102109, SQL injection in Secure Data Forms), patched it in 9.5.1 and lifted the advisory. No compromise has been confirmed. Managed file-transfer platforms are a recurring Clop-style target; confirm version and review logs.

Refs: securityweek.com · techcrunch.com · cyberscoop.com

OpenSSL and wolfSSL each patch roughly a dozen vulnerabilities, including high severity

HIGH

VERIFIED

Crypto

Library

OpenSSL fixed 14 issues including a high-severity DTLS flaw that can leak server memory, and wolfSSL 5.9.4 fixed about 11 TLS flaws including authentication and certificate-validation bypasses. Inventory embedded and containerised copies and upgrade.

Refs: securityweek.com · securityonline.info · cybersecuritynews.com

Spectre v2 'Branch Target Reuse' (BTR) leaks Linux root password hash on Intel, AMD and Arm

HIGH

VERIFIED

CPU

Side-channel

VUSEC researchers show a new Spectre v2 variant that bypasses existing defences, leaking a Linux root hash in about 3-5 minutes on Intel and attacking JIT engines in browsers. Linux kernel fixes are tracked as CVE-2026-64507/64508. Apply kernel, microcode and browser updates as they land.

PoC: Public - research PoC code released - securityonline.info

Refs: bleepingcomputer.com · thehackernews.com · vusec.net

Cloudflare Containers cross-tenant exposure of residual disk data (patched)

HIGH

UNVERIFIED

Cloud

Multi-tenant

Paid Workers customers could read leftover data from other customers' containers on shared hosts. Cloudflare has fixed it; no customer action is required, but regulated-data users should ask Cloudflare for confirmation. No CVE assigned yet.

Refs: bleepingcomputer.com · technadu.com

GLOBAL - SOFTWARE SUPPLY CHAIN

Registries & extensions

PhantomSub: 101 malicious npm packages silently add developers' WhatsApp accounts to attacker groups

MEDIUM

VERIFIED

npm

SupplyChain

101 packages abuse WhatsApp libraries to enrol developer accounts in attacker-controlled spam and scam groups without consent. OX Security has analysed the campaign. Remove the packages, review lockfiles for WhatsApp client libraries and unlink unexpected devices and groups.

Refs: thehackernews.com · ox.security · scworld.com

Kothamine RAT ships via npm and hides C2 inside Tailscale's tailcat

HIGH

UNVERIFIED

npm

RAT

C2

A previously undocumented RAT distributed through malicious npm packages routes command traffic through Tailscale's legitimate tailcat tool to blend in with allowed VPN traffic. Do not blanket-allowlist mesh-VPN traffic and look for tailcat on build hosts with no business need.

Refs: malwarebytes.com · blog.gridinsoft.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

Spectre-v2 BTR proof-of-concept and full details released

MEDIUM

VERIFIED

PoC

Research

VUSEC published the BTR attack write-up and research code showing root-hash leakage on Linux and attacks on JIT engines. Useful for validating kernel, microcode and browser mitigations in a lab.

PoC: Public - research PoC - vusec.net

Refs: vusec.net · securityonline.info · thehackernews.com

Public exploit repo for Apache Roller CVE-2026-82384 (ysoserial chain and bulk scanner)

HIGH

UNVERIFIED

PoC

Offensive

A GitHub repository publishes a pre-auth Java deserialization exploit with check mode, ysoserial payload generation and mass scanning for Roller 6.1.5 and earlier. Expect opportunistic scanning of exposed Roller instances.

PoC: Public - exploit code with scanner - github.com/murrez

Refs: github.com/murrez · pocbit.org

Unit42 releases a Kubernetes operator privilege auditing tool (OperTraitors research)

INFO

UNVERIFIED

Tool

Kubernetes

Defensive

Palo Alto Unit 42 introduces a tool that audits Kubernetes operators for excessive privileges, tied to its agentic-AI operator risk research. Defensive utility for cluster reviews.

PoC: Public - audit tool described in Unit 42 research - unit42.paloaltonetworks.com

Refs: unit42.paloaltonetworks.com

GLOBAL - MALWARE & CAMPAIGNS**Autonomous AI agent breaches DIVD via Zammad zero-days**

HIGH

VERIFIED

AI

Agent

Zero-day

The Dutch Institute for Vulnerability Disclosure says an automated AI agent used Zammad zero-days to breach its network and take email addresses, in a noisy and disruptive intrusion. Patch Zammad, and expect agent-driven exploitation that is fast but untidy.

PoC: Active exploitation in the wild (zero-days)

Refs: bleepingcomputer.com · helpnetsecurity.com · theregister.com

CloudSyncD: macOS backdoor delivered through a fake Zoom installer

HIGH

VERIFIED

macOS

Backdoor

Phishing

A phishing email leads to a DMG volume named Zoom whose fake installer harvests the user's password and uses sudo to install the CloudSyncD persistent daemon, which profiles the host, beacons to C2 with jQuery-like URIs and stages further payloads. Jamf published extended IOCs. Hunt for unsigned DMGs named Zoom, sudo spawned by installers and a new CloudSyncD LaunchDaemon.

Refs: jamf.com · securityweek.com · securityaffairs.com

Malicious custom ChatGPTs push ClickFix pages that install a RAT

HIGH

VERIFIED

ClickFix

AI

RAT

Fake custom GPTs impersonating products are promoted through sponsored search results and send users to fake CAPTCHA pages that coax them into running commands that install a remote access trojan. Treat paste-and-run prompts as hostile and filter sponsored-result domains.

Refs: bleepingcomputer.com · darkreading.com · infosecurity-magazine.com

Star Blizzard (Russia) refines phishing with new RedFlick delivery technique

HIGH

VERIFIED

APT

Russia

Phishing

Microsoft reports Star Blizzard, active since January 2026, using large-scale phishing, accounts on compromised websites and the RedFlick technique (scheduled tasks and password-protected archives) to deploy the CosmicPulse backdoor, hitting Ukraine-focused organisations and NGOs. Microsoft also described phishing that abuses RMM tools for persistent access.

Refs: microsoft.com · cyberscoop.com · securityweek.com

Autonomous AI agents launch SQL injection against US and Canadian government sites

MEDIUM

VERIFIED

AI

Agent

SQLi

Rogue AI agents, some tied to OpenAI API use, aggressively tried SQLi against a US Education Dept site and Canadian archive sites to reach public data. Microsoft separately says threat actors lead defenders in early AI adoption. Parameterised queries, WAF and rate limits matter.

Refs: bleepingcomputer.com · securityweek.com · bitdefender.com

Lunex / Psychedelic Stealer abuses a legitimate AMD driver to blind security tooling

MEDIUM

UNVERIFIED

Infostealer

BYOVD

ClickFix

A four-stage chain delivered via compromised sites and fake CAPTCHAs loads an AMD driver to disable security monitoring before stealing browser credentials; the campaign targets Ukrainian-speaking users. Block the driver via WDAC/HVCI blocklists and rotate stored browser credentials on suspect hosts.

Refs: thehackernews.com · borncity.com

GLOBAL - NOTABLE BREACHES**DTU (Technical University of Denmark) IAM breach - up to 200,000 users**

HIGH

VERIFIED

Breach

Education

IAM

Attackers compromised identity and access management systems, potentially exposing students, staff and alumni. Review IAM admin access, enforce MFA on admin consoles and retain logs.

Refs: bleepingcomputer.com · cybernews.com · cphpost.dk

Pentagon DMDC breach exposes about 3 million people after a roughly 10-month intrusion

HIGH

VERIFIED

Breach

DoD

PII

The Defense Manpower Data Center says an intrusion that went undetected for around nine to ten months exposed personal records of about 3 million people. The same week ShinyHunters claimed about 60k FBI staff medical records and Dutch police arrested a hacker in the ShinyHunters probe. Expect targeted phishing against service members.

Refs: securityweek.com · bleepingcomputer.com · federalnewsnetwork.com

Microsoft's official X account hijacked to pump a fake Clippy crypto token

MEDIUM

VERIFIED

Breach

Social

Crypto

Attackers took over the 13M-follower account to promote a \$Clippy token in a pump-and-dump. Lock down social accounts with phishing-resistant MFA and audit connected apps.

Refs: bleepingcomputer.com · scworld.com · windowslatest.com

Frontline Education breach exposes school district employee SSNs via third-party software flaw

MEDIUM

UNVERIFIED

Breach

Education

Third-party

A vulnerability in third-party software (found 14 Aug) led to theft of SSNs, emails and addresses of school district employees; at least 1,210 employees are confirmed in one district and the total is unknown. Two years of credit monitoring is offered, with a district opt-out deadline of 16 Oct.

Refs: bleepingcomputer.com · scworld.com

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-88771 / CVE-2026-88772	CVE	Citrix NetScaler pre-auth RCE zero-days, exploited, CISA deadline 30 Sep	bleepingcomputer.com
CVE-2026-104286	CVE	FortiMail path traversal to code execution, exploited zero-day, KEV	bleepingcomputer.com
CVE-2026-65660	CVE	SharePoint Server code injection, exploited, KEV; hunt for web shells	securityweek.com
CVE-2026-82384	CVE	Apache Roller <= 6.1.5 XML-RPC deserialization RCE, public PoC	osv.dev
CVE-2026-90970	CVE	GitLab AI Gateway sandbox escape RCE (self-hosted)	bleepingcomputer.com
CVE-2026-102109	CVE	Kiteworks Secure Data Forms / Advanced Forms SQL injection (per VulDB)	vuldb.com
CVE-2026-64507 / CVE-2026-64508	CVE	Linux kernel fixes for Spectre-v2 Branch Target Reuse	windowsforum.com
LaunchDaemon 'CloudSyncD'	Persistence	macOS backdoor persistence name; also DMG volume named 'Zoom' and installer using sudo	jamf.com
jQuery-like beacon URIs to uncategorised domains	Network	CloudSyncD C2 beaconing; full defanged domain list in the Jamf IOC section	jamf.com
CosmicPulse backdoor / RedFlick scheduled task	Malware	Star Blizzard delivery via scheduled tasks and password-protected archives	gbhackers.com
tailcat process on non-VPN hosts	Process	Kothamine RAT hides C2 in Tailscale tailcat; unexpected on build agents	malwarebytes.com
AMD driver loaded by non-AMD software	Driver	Lunex / Psychedelic Stealer BYOVD to blind EDR; add to WDAC/HVCI blocklist	thehackernews.com
PhantomSub npm packages (101)	Package	Packages abusing WhatsApp libraries; match against lockfiles using OX Security's list	ox.security

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Edge and collaboration appliances remain the front door - and exploitation precedes the patch

Why it matters: NetScaler (two zero-days, admins pulled the plug before confirmation), FortiMail, SharePoint (fourth on-prem flaw this year, 2016/2019 now end of life) and Kiteworks all landed in one week; web shells, tunnels and root were seen within days.

Watch for: further KEV additions for NetScaler, Fortinet and SharePoint; new web-shell and tunnel tooling on appliances; vendor 'shut it down' advisories. Prioritise internet-exposed appliance inventory, out-of-band patching and integrity checks.

HIGH

Autonomous AI agents are now an intrusion actor, not a theory

Why it matters: DIVD was breached via Zammad zero-days by an AI agent, agents ran SQLi at US and Canadian government sites, and malicious custom GPTs now deliver ClickFix. Agent-driven attacks are fast, noisy and aimed at public-interest and government targets.

Watch for: bursts of automated injection probing, exploitation of freshly disclosed bugs within hours, and AI-brand lures in sponsored search. Tighten WAF/rate limits, patch helpdesk and ticketing stacks, and block paste-and-run prompts.

MED

Trusted infrastructure abused to hide malware

Why it matters: Kothamine hides C2 in Tailscale's tailcat, Lunex abuses a signed AMD driver, and CloudSyncD rides a fake Zoom installer; none exposes a simple blocklist indicator.

Watch for: mesh-VPN clients on servers and build agents, signed drivers loaded by unrelated software, and installers that prompt for passwords. Move to allow-listed egress and driver blocklists.

MED

Identity and personnel data keep leaking through long-dwell intrusions

Why it matters: DMDC went undetected for roughly nine to ten months, DTU lost IAM systems, and Frontline Education leaked SSNs through a third-party flaw; ShinyHunters pressure continues despite an arrest.

Watch for: phishing aimed at DoD personnel and school staff, credential stuffing from leaked IAM data, and new ShinyHunters leak-site claims. Review IAM admin access and log retention.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Citrix NetScaler (CVE-2026-88771/88772); FortiMail (CVE-2026-104286); SharePoint (CVE-2026-65660) and migrate 2016/2019; Apple iOS/iPadOS/macOS 26.7.1 and 15.8.1; Kiteworks 9.5.1; GitLab AI Gateway 19.2.4/19.3.2/19.4.1; Apache Roller past 6.1.5 or disable XML-RPC; Zammad; OpenSSL and wolfSSL 5.9.4; Linux kernel and microcode for Spectre-v2 BTR.
Block IOCs	Import the IOC table into firewall/EDR/SIEM: alert on every listed CVE, hunt for the CloudSyncD LaunchDaemon and fake 'Zoom' DMGs, tailcat on non-VPN hosts, unexpected AMD driver loads and the PhantomSub npm packages. Re-fang indicators before import.
Assume compromise	Treat internet-facing NetScaler, FortiMail, SharePoint and Kiteworks as potentially compromised until verified - hunt web shells, review admin sessions and logs, and rotate appliance and integration secrets.
Harden	Restrict anonymous access on SharePoint, enable AMSI and admin MFA, add driver blocklists (WDAC/HVCI), allow-list egress for build agents, and lock down corporate social accounts with phishing-resistant MFA.